

Compte rendu TP 5- Protection du serveur web

Sommaire

Introduction	1
Partie A — Isolation du serveur WebFTP : Rendre l'invisible opérationnel	2
1. Ma démarche d'analyse	2
2. Mise en œuvre technique	2
3. Validation de l'isolation	2
Partie B — Déploiement du Serveur de Fichiers (FileZilla)	3
1. Organisation et Nomenclature	3
2. Architecture des droits d'accès	3
3. Sécurité renforcée	3
Partie C — Stratégie de Sauvegarde : La règle du "Zéro Perte"	3
Conclusion	4

Introduction

Dans le cadre du projet Galaxy Swiss Bourdin (GSB), ma mission consistait à refondre la sécurité de l'infrastructure réseau. Jusqu'ici, le serveur WebFTP partageait le même segment que les utilisateurs (172.30.0.0/16), ce qui représentait une faille majeure. J'ai donc pris l'initiative d'isoler ce serveur critique dans un réseau privé de classe A (10.0.0.0/8) et de déployer un serveur de fichiers sécurisé pour la gestion des comptes rendus.

Partie A — Isolation du serveur WebFTP : Rendre l'invisible opérationnel

1. Ma démarche d'analyse

Avant de toucher à la configuration, j'ai cartographié l'existant. Mon objectif était clair : sortir le serveur du champ de vision des postes clients. Pour y parvenir, j'ai planifié trois étapes clés :

- Le passage à un adressage en 10.x.x.x/8.
- La création d'une interface virtuelle dédiée sous VirtualBox.
- La mise en place d'un accès indirect pour les utilisateurs (via redirection) afin de concilier sécurité et disponibilité.

2. Mise en œuvre technique

Le déploiement s'est fait en deux temps :

- Côté Infrastructure (VirtualBox) : J'ai configuré un réseau "Hôte uniquement" pour cloisonner physiquement la VM.
- Côté Système (Windows 7) : J'ai migré l'adressage IP manuellement, en passant d'un masque de sous-réseau en /16 à un /8 plus vaste, spécifiquement dédié à notre zone d'administration.

3. Validation de l'isolation

Pour prouver l'efficacité de ma configuration, j'ai mené des tests de connectivité rigoureux.

Résultat : Le serveur ne répond plus au "ping" depuis le réseau utilisateur (isolation réussie), mais les services web restent accessibles grâce à la configuration de routage que j'ai établie.

Test réalisé	Cible	Résultat attendu	État
Ping d'étanchéité	10.x.x.x	Échec (Invisible)	✓ OK
Accès Web GSB	Navigateur	Succès (Service maintenu)	✓ OK

Accès FTP Direct	Port 21	Refusé (Sécurité)	 OK
------------------	---------	-------------------	--

Partie B — Déploiement du Serveur de Fichiers (FileZilla)

1. Organisation et Nomenclature

Pour garantir une gestion efficace des comptes rendus, j'ai instauré une règle de nommage stricte, essentielle pour l'archivage à long terme :
AAAA-MM-JJ_[Moment]_[Secteur].pdf.

Exemple : 2024-03-15_M_Labo1.pdf

2. Architecture des droits d'accès

J'ai choisi d'utiliser FileZilla Server pour sa souplesse. Mon travail s'est concentré sur la création d'une arborescence hiérarchisée et surtout sur la gestion fine des permissions (ACL) :

- Rapporteurs : Peuvent déposer des fichiers (Write Only), mais pas modifier l'existant.
- Employés : Accès en lecture seule, strictement limité à leur propre secteur (cloisonnement horizontal).
- Direction Générale : J'ai créé un profil "super-utilisateur" avec une vue récursive sur l'ensemble des dossiers.

3. Sécurité renforcée

Le serveur de fichiers profite de l'isolation réseau mise en place en Partie A. J'ai également configuré le Pare-feu Windows pour filtrer les flux et n'autoriser le protocole FTP que sur la plage IP sécurisée.

Partie C — Stratégie de Sauvegarde : La règle du "Zéro Perte"

Conscient que la sécurité ne s'arrête pas au réseau, j'ai identifié les actifs critiques à protéger : configurations Apache, bases de données, dossiers de comptes rendus et paramétrage FTP.

Mes actions mises en place :

1. Automatisation : Création de snapshots VirtualBox quotidiens.

2. Externalisation : Script de copie des données vers un lecteur réseau distant.
3. Traçabilité : J'ai intégré un journal de bord via `gestionnaire_sauvegardes.html` pour assurer un suivi rigoureux des opérations.

Conclusion

Ce TP a été pour moi une opportunité concrète de manipuler des concepts de Défense en Profondeur. J'ai appris que sécuriser une infrastructure ne signifie pas seulement "bloquer", mais surtout "organiser" les flux pour que l'utilisateur travaille sereinement sans même se rendre compte de la complexité du réseau qui le protège.